SIMATS ENGINEERING

CSA6303- Threat Intelligence and Network Security

A1-Threat Intelligence Report

Assessment Questions

Subject	Threat Intelligence	**Total Marks**	50
Questions	5 (all compulsory)	**Marks per Question**	10
Reg. No	192465054	**Name**	A Abhinava Reddy
Faculty	Dr.V.Parthipan	**Slot**	A

Instructions: Answer all questions. Each question carries 5 marks. Support answers with examples and diagrams where appropriate.

CO3: Perform threat analysis using intelligence models and utilize industry tools for monitoring and detection.

Code of Conduct:

I A Abhinava Reddy,192465054(Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of Student

A Abhinava reddy

Threat Hunting, SIEM and Security Monitoring

Scenario-Based Answers (Questions 1 to 5)

Question 1: Threat Hunting Techniques [10 Marks]

An organization suspects that an attacker has gained unauthorized access to its internal network. The security team observes unusual login times, unexpected processes, and connections to unfamiliar external servers. Describe the proactive threat-hunting techniques you would use to investigate the activity and identify potential threats.

Introduction

Threat hunting is the proactive, human-led search through networks, endpoints and logs for adversaries that have evaded automated defences. Unlike alert-driven monitoring, it starts from the assumption that a breach has already happened ("assume breach"). Here, three symptoms (odd login times, unexpected processes and unfamiliar outbound connections) point to a possible compromised account, a foothold on an endpoint and a command-and-control (C2) channel.

Step 1: Form hypotheses and map them to MITRE ATT&CK

- **Hypothesis 1:** A valid account has been stolen and is being used outside normal hours (ATT&CK T1078, Valid Accounts).
- **Hypothesis 2:** Malware or a living-off-the-land tool is running and has set up persistence (T1053 Scheduled Task, T1547 Registry Run Keys, T1059 PowerShell).
- **Hypothesis 3:** The host is beaconing to an attacker server (T1071 Application Layer Protocol, T1041 Exfiltration over C2).

Step 2: Collect and prepare data

Gather authentication logs (Active Directory, VPN, SSO), endpoint telemetry (Sysmon, EDR), DNS, proxy and firewall logs, NetFlow, and email gateway logs into a SIEM or data lake. Normalise timestamps to one time zone and establish a baseline of "normal" for users, hosts and servers.

Step 3: Apply hunting techniques

a) Login and identity hunting

- Compare logins against each user's baseline hours and locations; look for impossible travel and logins from new devices.
- Hunt for failed-then-successful logon patterns (Event IDs 4625 followed by 4624), privileged logons (4672), explicit-credential use (4648), and Kerberos anomalies (4768/4769) that suggest password spraying or Kerberoasting.
- Trace lateral movement through network logons (Type 3) and RDP (Type 10) between hosts that do not normally talk to each other.

b) Process and endpoint hunting

- Examine parent-child relationships, for example winword.exe or outlook.exe spawning powershell.exe or cmd.exe.
- Use stack counting (least-frequency analysis): processes or hashes present on only one or two machines are suspicious.
- Flag unsigned binaries, executables running from Temp, AppData or Downloads, renamed system tools, and misuse of LOLBins such as certutil, bitsadmin, mshta and rundll32.
- Check persistence locations: Run keys, scheduled tasks, new services, WMI event subscriptions and newly created local or domain accounts.

c) Network hunting

- Beaconing analysis: connections to the same external IP or domain at regular intervals with small, uniform payloads.

- Rare-destination analysis: newly registered domains, unusual ports, direct-to-IP connections, long-lived sessions and abnormal user-agents or TLS fingerprints (JA3).
- DNS hunting: very long or high-entropy subdomains (DNS tunnelling) and algorithmically generated domains (DGA).

d) Intelligence-driven hunting

- Match IPs, domains and file hashes against threat-intelligence feeds (MISP, AlienVault OTX, VirusTotal) and hunt for known attacker TTPs rather than only indicators of compromise (IOCs).

e) Statistical and behavioural analysis

- Use clustering, outlier detection and user and entity behaviour analytics (UEBA) to surface hosts or accounts whose behaviour deviates from peers.

Step 4: Investigate, validate and respond

Pivot between findings (user, host, process, destination) to build a timeline and find the first compromised system (patient zero). Confirm true positives, then isolate affected hosts, reset credentials, block malicious IPs and domains, and preserve evidence for forensics.

Step 5: Document and improve

Record the hypotheses, queries, findings and gaps; convert successful hunts into permanent SIEM detection rules so the same technique is caught automatically in future.

Conclusion

A hypothesis-driven hunt combining identity, endpoint, network and intelligence-based techniques lets the team confirm whether the attacker is present, determine the scope, and remove the threat while strengthening future detection.

Question 2: SIEM Tools and Security Monitoring [10 Marks]

A company implements a Security Information and Event Management (SIEM) system to monitor its network. The system generates multiple alerts about suspicious login attempts and unusual outbound connections. Explain how the SIEM system can collect and analyze security events, correlate alerts, and help security analysts prioritize potential threats.

Introduction

A SIEM combines Security Information Management (long-term log storage and reporting) with Security Event Management (real-time monitoring and alerting). It gives analysts one place to see what is happening across firewalls, servers, endpoints, applications and cloud services. Common products include Splunk, IBM QRadar, Microsoft Sentinel, ArcSight and the open-source ELK Stack.

1. Collection of security events

- **Sources:** firewalls, IDS/IPS, routers, domain controllers, VPN, web and database servers, EDR agents, DNS, proxies, email gateways and cloud platforms.
- **Methods:** agents or forwarders on hosts, syslog, SNMP traps, API pulls and log shippers such as Beats or Logstash.
- **Normalisation and parsing:** logs arrive in different formats, so the SIEM parses them into a common schema (user, source IP, destination IP, action, time) and standardises timestamps.
- **Storage and indexing:** events are stored and indexed for fast search, and retained for investigation and compliance (PCI-DSS, ISO 27001, HIPAA).

2. Analysis of events

- **Rule-based detection:** predefined rules, such as "more than 10 failed logins in 5 minutes".
- **Statistical and behavioural analysis:** baselines and UEBA detect deviations such as a user logging in at 3 a.m. for the first time.
- **Enrichment:** IPs and domains are checked against threat-intelligence feeds and tagged with geolocation, asset owner and user role.
- **Dashboards and search:** analysts query and visualise events to explore suspicious activity.

3. Correlation of alerts

Correlation links separate low-level events into one meaningful incident. Individually, a failed login or an outbound connection may be harmless; together, they can show an attack chain.

Individual alerts	Correlated conclusion
Many failed logins from one IP against several accounts	Possible brute-force or password-spraying attempt
A successful login from the same IP shortly afterwards	Probable account compromise
New process created on that user's workstation	Possible malware or attacker tool execution
Outbound connection to a rare or blacklisted external IP	Probable C2 communication or data exfiltration

A correlation rule could therefore read: "If 10 or more failed logins are followed by a success from the same source, and the same host connects to an external IP flagged by threat intelligence within

30 minutes, raise a High-severity incident." Correlation also supports time-window, sequence and cross-source (identity + endpoint + network) matching.

4. Prioritisation of threats

- **Risk scoring:** each alert is scored using severity, asset criticality (a domain controller outranks a test machine), user privilege, threat-intel confidence and the attack stage (mapped to MITRE ATT&CK).
- **Aggregation and de-duplication:** many related alerts are grouped into one incident to reduce alert fatigue.
- **False-positive tuning:** whitelists, thresholds and rule refinement keep the queue focused on real threats.
- **Triage workflow:** high-risk incidents are escalated first, assigned through case management, and can trigger automated playbooks (SOAR) such as disabling an account or blocking an IP.
- **Reporting:** dashboards and scheduled reports show trends, mean time to detect and respond, and support audits.

Conclusion

By collecting and normalising logs, analysing them with rules, baselines and threat intelligence, correlating related alerts and scoring them by risk, the SIEM turns a flood of raw events into a short, ranked list of incidents that analysts can act on quickly.

Question 3: Security Monitoring and Anomaly Detection [10 Marks]

A company's security monitoring dashboard identifies a sudden increase in outbound network traffic during non-working hours. The activity originates from a database server that normally transfers only small amounts of data. Explain how you would investigate the anomaly, identify possible data exfiltration, and recommend suitable monitoring and prevention measures.

Introduction

Anomaly detection compares current behaviour with an established baseline. A database server that suddenly sends large volumes of data outside working hours deviates sharply from its baseline and is a classic indicator of data exfiltration, so it must be treated as a potential breach until proven otherwise.

A. Investigating the anomaly

1. **Validate the alert.** Confirm the spike is real, not a monitoring error. Check change calendars and with the DBA team for scheduled backups, replication, batch jobs or migrations.
2. **Scope the activity.** Using NetFlow, firewall and proxy logs, identify the destination IPs and domains, ports and protocols, the volume transferred, start and end times, and whether other servers show similar behaviour.
3. **Check the destination.** Run reputation and geolocation checks and WHOIS age on the external addresses; consider cloud-storage services, personal mail, FTP or unknown hosts as suspicious.
4. **Examine the database server.** Review database audit and query logs for bulk SELECT or export commands, dump utilities, unusual accounts, queries on sensitive tables and privilege changes.
5. **Examine the operating system and processes.** Look for unknown processes, scheduled tasks, new services, compression tools creating large archives (zip, rar, 7z), and remote-access tools, using EDR telemetry.
6. **Review identity activity.** Check which account initiated the transfer, from where it logged in, and whether it was compromised or an insider.
7. **Inspect traffic content where possible.** Capture packets (Wireshark or Zeek) to look for large encrypted uploads, DNS tunnelling, or encoded payloads.

B. Indicators of data exfiltration

- Large, sustained outbound transfers to a previously unseen external destination.
- Bulk database reads followed immediately by an outbound upload.
- Compressed or encrypted archives created just before the transfer.
- Use of unusual channels such as DNS, ICMP or non-standard ports, and activity at odd hours.
- Use of a service or administrator account that does not normally perform these actions.

C. Immediate response

- Isolate the server from the network (or throttle egress) while preserving volatile evidence and taking a forensic image.
- Block the malicious destinations at the firewall and proxy; disable or reset compromised credentials.

- Determine exactly which records were accessed or sent, classify their sensitivity, and engage legal and compliance teams on breach-notification duties (for example under India's DPDP Act 2023 or other applicable laws).
- Eradicate the root cause, restore from a clean state and monitor closely after recovery.

D. Recommended monitoring measures

- Baseline-driven alerts on outbound volume, time of day and destination for critical servers, with SIEM correlation rules.
- Database Activity Monitoring (DAM) to log and alert on bulk queries and privileged access.
- NetFlow/Zeek analysis, DNS monitoring and UEBA to catch abnormal behaviour.
- EDR on servers and centralised log collection with adequate retention.

E. Recommended prevention measures

- **Egress filtering:** servers may connect out only to approved destinations; deny all other outbound traffic by default.
- **Data Loss Prevention (DLP):** inspect and block outbound transfers of sensitive data.
- **Network segmentation:** place databases in a restricted zone reachable only from application servers.
- **Least privilege and MFA:** limit database and administrator rights, rotate credentials and require multi-factor authentication.
- **Encryption and masking:** encrypt data at rest and in transit and mask sensitive fields to reduce the impact of theft.
- **Patching, hardening and audits:** keep systems updated, review access regularly, run incident-response drills, and use honeytokens or decoy records to detect theft early.

Conclusion

A structured response of validating, scoping, analysing the server and traffic, containing the incident and then hardening monitoring and egress controls lets the organisation confirm whether data was stolen, limit the damage and make a repeat incident far less likely.

Question 4: Tools Used in the IT Industry for Threat Hunting [10 Marks]

An IT organization suspects that malware has infected several employee workstations. The security team has access to SIEM software, endpoint detection tools, network traffic analyzers, and vulnerability scanners. Select suitable tools for investigating the incident and explain how each tool can help identify, analyze, and contain the threat.

Introduction

No single tool can handle a malware outbreak. Each of the four available tool categories covers a different view of the incident (logs, endpoints, network and weaknesses), and together they let the team identify the infection, analyse its behaviour and contain it.

Tool category	Suitable tools	How it helps: identify, analyse, contain
SIEM	Splunk, IBM QRadar, Microsoft Sentinel, ELK Stack	Identify: correlates alerts from many sources and searches for the malware's IOCs (hashes, domains, IPs) across all workstations. Analyse: builds a timeline from logon events, process creation and DNS or proxy logs to find patient zero and the spread. Contain: raises prioritised incidents and, with SOAR playbooks, can disable accounts or push block lists.
Endpoint Detection and Response (EDR)	CrowdStrike Falcon, Microsoft Defender for Endpoint, SentinelOne, Sysmon with Wazuh	Identify: detects malicious behaviour such as suspicious scripts, ransomware-like file changes and credential dumping on each workstation. Analyse: shows process trees, file and registry changes, persistence and network connections per host, and supports memory and file inspection. Contain: can kill processes, quarantine files and isolate an infected workstation from the network with one action.
Network traffic analyzers	Wireshark, Zeek, Suricata/Snort, NetworkMiner, NetFlow tools	Identify: spots C2 beaconing, DNS tunnelling, scanning and lateral movement. Analyse: packet captures reveal the protocols, payloads, and downloaded files, and IDS signatures confirm known malware traffic. Contain: the findings feed firewall, proxy and DNS rules that block malicious IPs and domains, and IPS mode can drop the traffic.
Vulnerability scanners	Nessus, OpenVAS, Qualys, Rapid7 InsightVM	Identify: finds missing patches, weak configurations and exposed services that the malware may have exploited. Analyse: scanning other workstations shows which are exposed to the same flaw and likely to be hit next. Contain: gives a prioritised patching and hardening list that closes the entry point and prevents reinfection.

Supporting tools

- **Threat intelligence:** VirusTotal, MISP and AlienVault OTX to check hashes, domains and IPs.
- **Sandboxes and malware analysis:** Cuckoo Sandbox, ANY.RUN, plus static tools such as PEStudio, and memory forensics with Volatility.

Suggested workflow

1. Use the **SIEM** to find the affected workstations and the earliest infection time.
2. Use **EDR** to inspect each host, collect the malware sample and isolate the workstations.
3. Use **network analyzers** to find the C2 servers and block them.
4. Use the **vulnerability scanner** to find and patch the weakness across the estate.
5. Feed the IOCs back into the SIEM and EDR as detection rules, then verify that the threat is gone.

Conclusion

Used together, the SIEM provides visibility and correlation, EDR gives host-level detail and containment, network analyzers expose the attacker's communication, and vulnerability scanners remove the weakness, giving a complete identify, analyse and contain cycle.

Question 5: Integrated Threat Hunting and Incident Reporting [10 Marks]

A company detects suspicious user logins, connections to a malicious domain, and an unknown process running on an employee workstation. The security team uses Splunk or the ELK Stack to analyze logs and a threat intelligence platform to verify suspicious indicators. Describe the complete threat-hunting process, including data collection, log correlation, threat investigation, malware analysis if required, risk assessment, and preparation of a threat-hunting report with recommended remediation actions.

Introduction

An integrated hunt joins several activities into one repeatable cycle: hypothesis, data collection, correlation, intelligence validation, investigation, malware analysis, risk assessment, response and reporting. The three observations (suspicious logins, a malicious-domain connection and an unknown process) suggest a compromised account that was used to run malware that communicates with an attacker.

Step 1: Define the hypothesis and scope

Hypothesis: "A user account was compromised, and an attacker-controlled process on the workstation is communicating with a malicious domain." Identify the user, workstation, time window and related assets, and map expected techniques to MITRE ATT&CK.

Step 2: Data collection

- Windows Security and Sysmon logs, VPN and Active Directory authentication logs, DNS, proxy and firewall logs, EDR telemetry and email logs.
- Collected using Splunk Universal Forwarders, or Beats and Logstash for ELK, then parsed, normalised and time-synchronised.
- Volatile data (running processes, network connections, memory) and disk artefacts are preserved from the workstation, with a documented chain of custody.

Step 3: Log correlation

Link events across sources by user, host, IP and time. Example Splunk searches:

```
index=wineventlog EventCode=4624 user="jdoe" | stats count by src_ip,
Logon_Type, host
index=proxy dest_domain="malicious-domain.example" | stats count by src_host,
user
index=sysmon EventCode=1 host="WS-045" | table _time, ParentImage, Image,
CommandLine
```

The equivalent can be built in Kibana (KQL). Correlating the results yields a timeline: suspicious login, then process creation, then DNS lookup and connection to the malicious domain, then any further lateral movement or data transfer.

Step 4: Threat-intelligence verification

Submit the domain, resolved IPs, file hashes and process names to the threat-intelligence platform (MISP, VirusTotal, AlienVault OTX, commercial feeds). Check reputation, domain registration age, associated malware families, campaigns and threat actors, and record the confidence level. Unverified indicators remain hypotheses until supported by other evidence.

Step 5: Threat investigation

- Analyse the process: path, parent process, command line, digital signature, hash, persistence entries and network connections.

- Determine how the attacker got in (phishing, stolen credentials, exploit) and identify patient zero.
- Search the whole environment for the same IOCs to find other affected hosts, check for lateral movement and privilege escalation, and determine whether data was accessed or exfiltrated.

Step 6: Malware analysis (if required)

- **Static analysis:** file hashes, strings, PE headers, imports and packer detection (PEStudio, strings).
- **Dynamic analysis:** run the sample in an isolated sandbox (Cuckoo, ANY.RUN) and observe file, registry, process and network behaviour.
- **Memory forensics:** examine a memory image with Volatility for injected code and hidden processes.
- Extract new IOCs (domains, IPs, mutexes, file names, registry keys) and write detection rules (YARA, Sigma, SIEM queries).

Step 7: Risk assessment

Risk is estimated as likelihood multiplied by impact, taking into account asset criticality, privileges of the compromised account, the sensitivity of data reachable, spread across the network, and the confidence of the intelligence.

Factor	Question	Example rating
Asset criticality	What does the workstation or account give access to?	Medium to High
Spread	How many hosts or accounts are affected?	Under assessment
Data exposure	Was sensitive data accessed or sent out?	Depends on findings
Threat confidence	How reliable is the intelligence on the domain and malware?	High if confirmed
Overall risk	Combined likelihood and impact	High (until contained)

Step 8: Containment, eradication and recovery

- Isolate the workstation, block the domain and IPs at the proxy, DNS and firewall, and disable or reset affected credentials and sessions.
- Remove the malware and persistence, patch the exploited weakness, and rebuild the machine from a trusted image if integrity is in doubt.
- Monitor closely after recovery to confirm there is no reinfection.

Step 9: Threat-hunting report

The report should be clear enough for both technical staff and management. A suitable structure is:

1. **Title, date, author and classification.**
2. **Executive summary:** what happened, impact, current status and key actions, in plain language.
3. **Scope and hypothesis:** systems, users and time period examined.
4. **Methodology and tools:** data sources, Splunk or ELK queries, threat-intelligence platforms and analysis methods.
5. **Timeline of events:** the correlated sequence from initial access to detection.

6. **Findings and evidence:** affected hosts and accounts, malware behaviour, screenshots and log excerpts.
7. **Indicators of compromise and MITRE ATT&CK mapping.**
8. **Risk assessment:** severity, likelihood, impact and confidence.
9. **Recommended remediation:** see below.
10. **Lessons learned and new detections created.**

Recommended remediation actions

Timeframe	Actions
Immediate	Isolate affected hosts; block malicious domains and IPs; reset passwords and revoke sessions and tokens; remove malware and persistence; preserve evidence.
Short term	Patch exploited vulnerabilities; enforce MFA; add the new IOCs and detection rules to SIEM, EDR and DNS filtering; scan the estate for the same indicators; review access of affected accounts.
Long term	Improve user phishing and security awareness training; apply least privilege and network segmentation; strengthen logging coverage and retention; schedule regular proactive hunts; update the incident-response plan and run drills.

Conclusion

By collecting the right data, correlating it in Splunk or ELK, verifying indicators with threat intelligence, analysing the malware, assessing risk and documenting everything in a structured report, the organisation can contain the current incident and convert what it learned into lasting improvements in detection and prevention.